



CRESTCON - RED TEAM COMMUNITY DAY

The Next Internal Network

Why Domain Admin Is No Longer the Finish Line

Rethinking what successful compromise looks like in the modern enterprise

Dumisani Masimini (Dumi) | Offensive Security Consultant, WorkNest Secure



**YOU GOT
DOMAIN ADMIN.**

HOW MUCH OF THE COMPANY DO YOU OWN?

Let's find out what "owning it" actually means.

LET'S MAKE THAT CONCRETE

What do you want?

If "owning the company" is the goal, pick your target. Which of these three would you actually choose for your next internal penetration test?



Domain Admin

The classic finish line



Global Admin

The cloud-era equivalent



The Crown Jewels

Whatever the business actually cares about

What we'll cover

1



The game we've always played

Two decades of Active Directory-centric pentesting

2



Why that game might be wrong

A question that changes how you measure success

3



Follow the trust

Real attack chains across the modern enterprise

4



What happens when you follow it

A composite compromise that never touches AD

5



A new way to measure compromise

Reach, blast radius, and a practical framework

FOR TWENTY YEARS

The pentester's finish line



SOUND FAMILIAR?

The path we've all drawn in BloodHound



Five hops. One well-worn methodology. A predictable, defensible objective.

**BUT WHAT IF
THE GAME IS WRONG?**



“

*“We got Domain Admin in four hours...
but the client's actual crown jewels lived
in a SaaS platform we never touched.”*

A sentence every pentester has quietly thought - and one every report should reckon with.



SO WHAT DID WE ACTUALLY PROVE?

Not what we thought. The enterprise underneath us has moved.

HERE'S WHAT MOVED

The architecture nobody re-scoped for



M365 / Entra ID

The default identity backbone for most enterprises today



Dozens of SaaS apps

Per organisation, each with its own admin plane and data



Multi-cloud by default

AWS, Azure and GCP control planes running in parallel



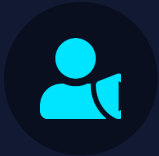
Fully managed endpoints

MDM/UEM platforms deciding what gets to connect at all

**PRIVILEGE IS NO LONGER
THE UNIT OF COMPROMISE.**

LET'S FIND OUT

Follow the trust



Identity Providers

Entra ID, Okta, Google
Workspace



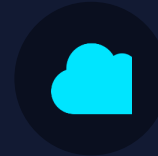
SaaS Platforms

Sensitive data & admin
control



Device Management

Intune, Jamf, endpoint trust



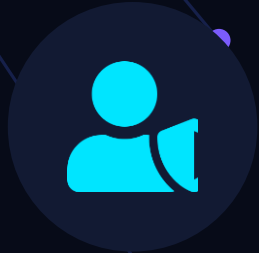
Cloud Admin Planes

AWS, Azure, GCP control
planes



OAuth & Federation

Cross-org trust relationships



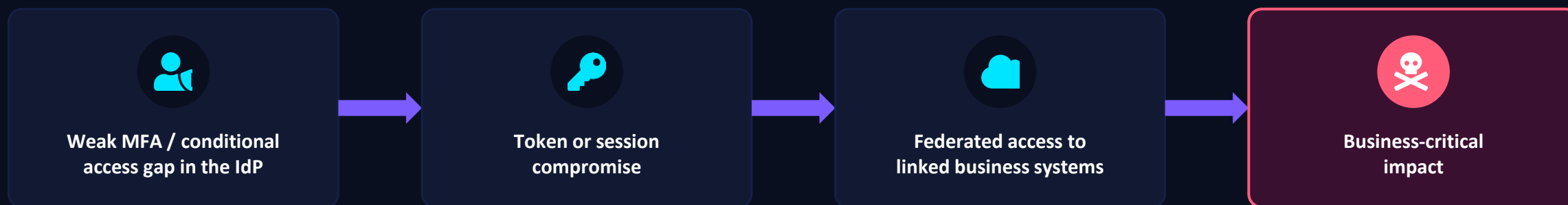
Identity Providers

What trusts my identity?

Why it matters

The identity provider is where authentication, MFA policy and conditional access converge for almost every downstream system. Compromise it and you often inherit trust everywhere federation reaches.

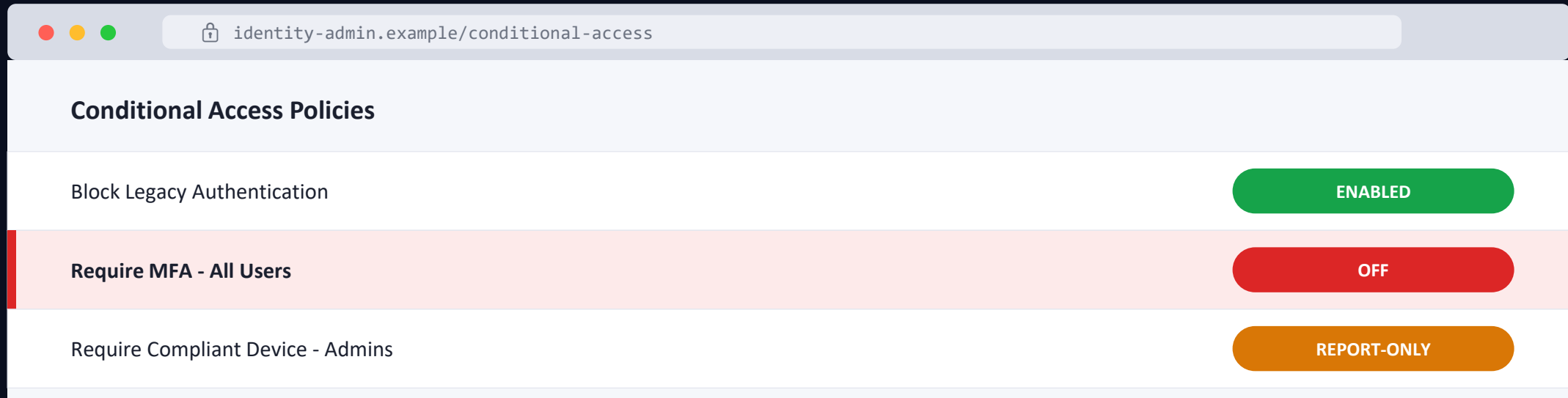
Identity provider as the new domain controller



Inspired by real-world patterns: a gap in conditional access or an admin session compromise on the identity provider gave access far beyond what any single on-prem AD compromise would have granted.

WHAT THIS LOOKS LIKE

The gap that let it happen



One policy, switched off. That's the entire gap between "we have MFA" and a help-desk phone call becoming Global Admin.



Device Management

What trusts my device?

Why it matters

MDM/UEM platforms decide which endpoints are allowed to authenticate, what policies they receive, and increasingly what certificates and secrets they're issued. It's a trust broker most assessments never touch.

Device management as an endpoint trust broker



Device management platforms decide which endpoints are trusted - compromise the platform and you inherit that trust across the entire fleet. This pillar is more research-driven than breach-driven today; treat it as where the field is heading, not a settled case study.



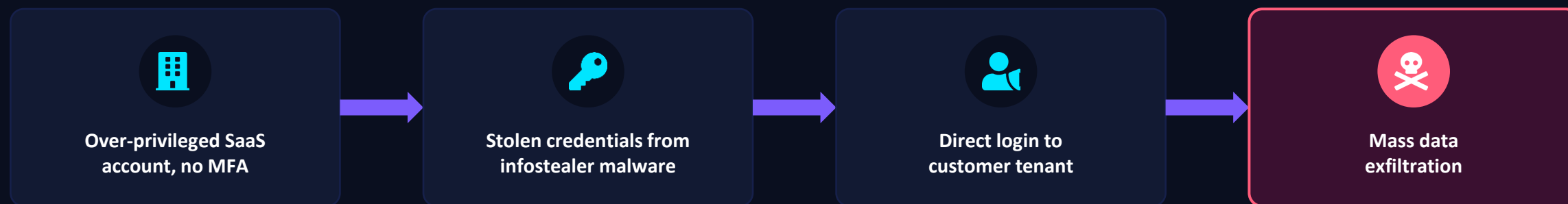
SaaS Platforms

Where does that trust take me?

Why it matters

SaaS applications increasingly hold the data and workflows attackers actually want - CRM records, financial systems, source code, HR data - all administered outside the domain entirely.

SaaS platforms holding the keys



SaaS platforms increasingly hold sensitive data and administrative control that never touches the Windows domain at all - and attackers don't need a platform vulnerability, just a valid stolen credential and no MFA.



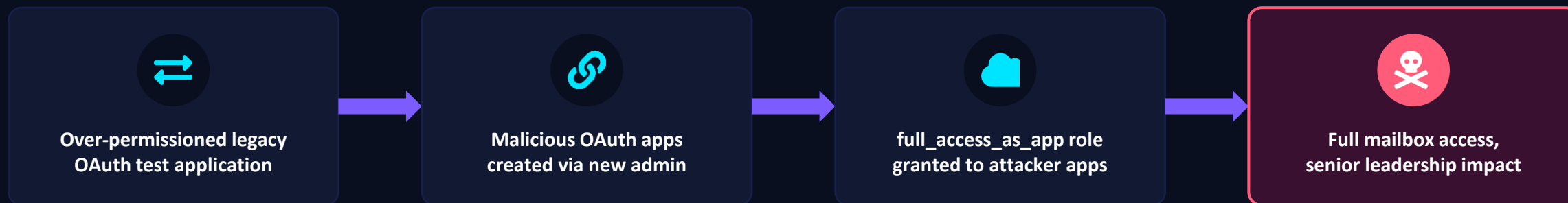
OAuth & Federation

What can that trust authorise?

Why it matters

OAuth consent and federated trust relationships quietly bridge organisational boundaries. A single over-scoped app registration can become a bridge into a partner's or customer's tenant.

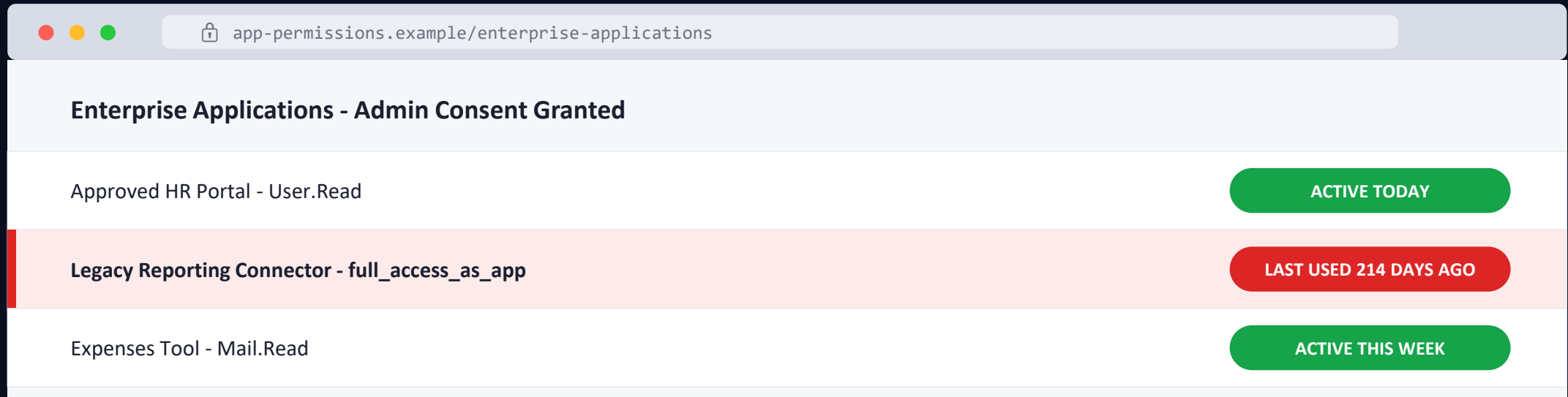
OAuth & federation: trust without borders



Federated identity introduces entirely new attack paths - a single forgotten, over-scoped OAuth application can become a bridge into an entire tenant, bypassing MFA and session controls altogether.

WHAT THIS LOOKS LIKE

The app everyone forgot about



Full mailbox access, granted years ago, never revoked. Nobody remembers this app exists - which is exactly why it's still dangerous.



Cloud Admin Planes

What can that trust become?

Why it matters

Cloud management planes often govern more infrastructure, with broader blast radius, than any on-premises domain ever did. IAM misconfigurations here can outrank Domain Admin entirely.

Cloud admin planes: broader than on-prem ever was



Cloud management planes often provide broader influence than on-premises infrastructure ever did - one control-plane compromise can outrank Domain Admin entirely. IAM misconfiguration remains one of the most consistently cited root causes across cloud breach research year over year.

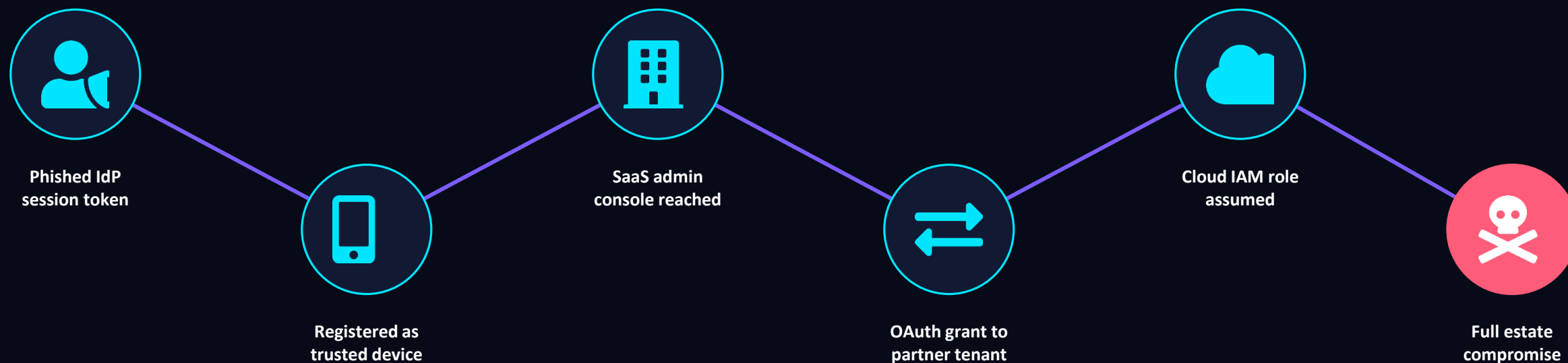
What this actually leaves behind

Pillar	What Gets Logged	Where To Look
Identity	Sign-in from new location/device, MFA method changes	Entra ID sign-in & audit logs
Device	New device registration, compliance state change	Intune audit logs, Entra ID device sign-ins
SaaS	New session from unfamiliar IP/ASN, role changes	Platform admin/audit logs, CASB/SSPM alerts
OAuth	New app registration, admin consent grant	Entra ID enterprise app & consent audit logs
Cloud	New/modified IAM policy, AssumeRole activity	CloudTrail / Activity Log / Cloud Audit Logs

Every pillar leaves a trail. Operate accordingly.

WATCH WHAT HAPPENS WHEN I FOLLOW TRUST

One identity. Five pillars. No Domain Admin.



No domain controller was ever touched. No BloodHound edge was ever walked.

**I NEVER NEEDED
DOMAIN ADMIN.**

**SO WHAT WAS
THE OBJECTIVE?**

REACH.

Trust is how you get there. Reach is what you're actually measuring.

NOT A NEW IDEA TO THIS ROOM

This is already how STAR is scoped

CREST's own Simulated Targeted Attack & Response methodology is built around a defined objective and a realistic threat scenario - not "get Domain Admin." STAR engagements already score success by what was reached, not which privilege badge was obtained.

SO WHY DOES DAY-TO-DAY PRACTICE STILL DEFAULT TO THE OLD FINISH LINE?

We have a metric problem

OLD METRIC

Privilege gained

Domain Admin

10 / 10

NEW METRIC

Trust traversed

Systems reached

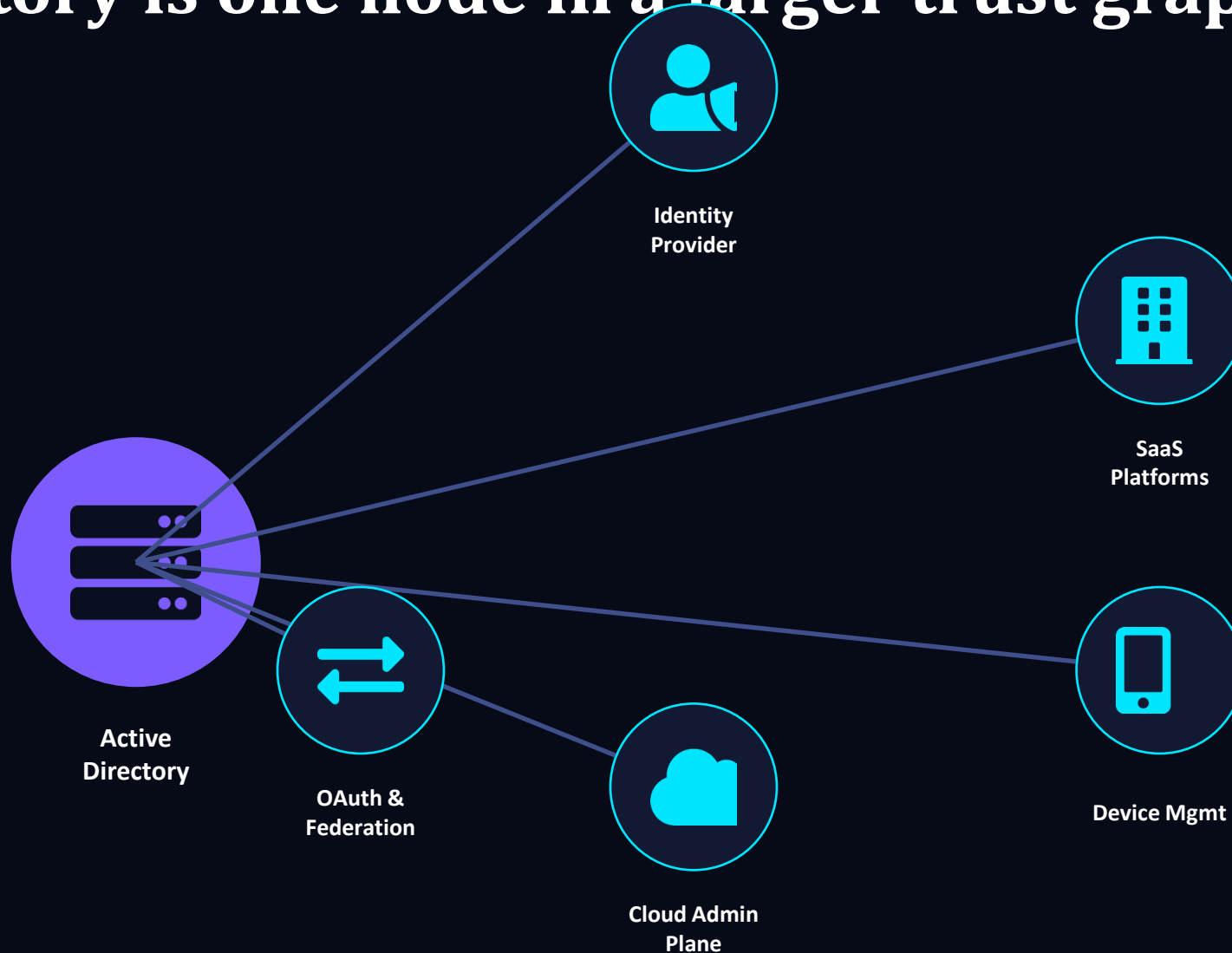
Data accessed

Business impact

Blast radius

**STOP REPORTING THE BADGE.
START REPORTING THE BLAST RADIUS.**

Active Directory is one node in a larger trust graph



Let's challenge the argument



Is this actually happening?

Yes - four of the five pillars have named, public breach evidence.



Is this really different from AD?

Yes - the trust relationships extend well beyond the domain boundary.



Is device management proven?

Not yet at the same level - it's an emerging, research-driven surface.

EMERGING



Are those screenshots real?

No - they're illustrative mockups of common patterns, not a real tenant.

MOCKUP

I'm deliberately separating what we know from what I think is coming.

TO BE CLEAR

This isn't a talk about the death of Active Directory



Active Directory remains a critical component of many enterprise environments.

What's changing is the assumption that compromising it is the finish line. AD is increasingly just one node - often a well-defended one - in a much larger, interconnected trust graph.

SO WHAT DO WE DO ABOUT IT

A practical framework for modern internal assessments

1



Map the full trust graph

Not just the domain - IdP, SaaS, devices, cloud, federation

2



Enumerate each pillar

Conditional access, app consents, IAM policies, MDM enrollment

3



Chain across boundaries

Look for privilege that crosses from one system into another

4

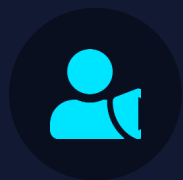


Redefine “game over”

You already know this one - blast radius, not badges

WHO THIS IS FOR

A new perspective, whichever seat you're in



Penetration Testers

Scope assessments beyond the domain boundary



Red Teamers

Chain identity, cloud and SaaS into real objectives



Blue Teamers

Extend detection to IdP, SaaS and device management



Security Leaders

Rethink where enterprise trust actually lives

What to carry back to your next engagement

1

The definition of the "internal network" has already changed - assessments need to catch up

2

Domain Admin is a milestone, not always the objective - trace paths through IdP, SaaS, cloud and device management too

3

Privilege is no longer the unit of compromise. Reach is - trust is how you get there, and a chain across a graph beats a single escalation



Thank you

Questions?

Dumisani Masimini (Dumi) | Offensive Security Consultant, WorkNest Secure

Evidence detail, pillar by pillar

Pillar	Evidence	Real-world anchor	Likely challenge
Identity Providers	Strong	MGM Resorts / Caesars, Sept 2023 (Scattered Spider) - help-desk vishing into Okta, \$100M+ impact	<i>"Doesn't hybrid sync tie this back to AD anyway?"</i>
Device Management	Emerging	Research-driven (Intune/Jamf misconfig talks) - no named headline breach yet	<i>"Has this actually happened in the wild?"</i>
SaaS Platforms	Strong	Snowflake customer breach, 2024 (UNC5537) - ~165 orgs, stolen creds, no MFA	<i>"Isn't this just a credential/MFA problem, not a new pillar?"</i>
OAuth & Federation	Strong	Microsoft corporate breach, Jan 2024 (Midnight Blizzard/APT29) - malicious OAuth apps	<i>"How common is this outside nation-state actors?"</i>
Cloud Admin Planes	Mature	Recurring root cause across cloud breach research for years (Pacu, ScoutSuite exist because of this)	<i>"Isn't cloud IAM misconfig old news - what's new here?"</i>

Not for the main talk - pull this up only if someone in Q&A pushes on a specific pillar's evidence.

Glossary

IdP

Identity Provider - the system that authenticates users and issues the tokens everything else trusts

Entra ID

Microsoft's cloud identity platform (formerly Azure AD)
- identity for M365 and beyond

SaaS

Software-as-a-Service - hosted applications you access over the web, not run on your own servers

MDM / UEM

Mobile / Unified Endpoint Management - platforms that enroll and enforce policy on devices

Intune

Microsoft's MDM/UEM platform for managing and securing devices

Jamf

A leading MDM platform built specifically for managing Apple devices

OAuth

An authorisation framework - lets an app act on a user's behalf without their password

full_access_as_app

An Exchange Online permission granting an app full mailbox access as itself, not as a user

IAM

Identity and Access Management - the roles and policies deciding who can do what to cloud resources